

Access Control Assessment Worksheet

RBAC, MFA, least privilege, segregation of duties, and access-review evidence

Assessment Objective

Evaluate representative identity and access controls for workforce users, administrators, service accounts, and third-party access. Findings demonstrate analyst methodology and are not claims about a specific employer environment.

Finding	Risk	Evidence expected	Recommendation	Priority
Privileged users use the same account for admin and normal work	Compromise of daily-use activity can expose elevated privileges.	Directory group export, account inventory, admin login records	Use separate admin accounts; phishing-resistant MFA; monitor privileged sessions.	Critical
Quarterly access review not consistently evidenced	Dormant or excessive access may persist.	Review attestations, manager approvals, removal tickets	Run quarterly recertification for privileged/high-risk groups; retain evidence.	High
Shared service account lacks named business owner	Weak accountability and secret governance.	Service-account inventory, owner field, usage logs	Assign technical/business owner; rotate secret; reduce permissions; consider managed identity.	High
Contractor access has inconsistent expiration	Third-party access can persist beyond business need.	HR/vendor dates, account expiry, access approvals	Set automatic expiry; sponsor review; disable on end date; quarterly exception review.	High
Legacy app does not support MFA	Password compromise has higher impact.	Application config, authentication flow, compensating controls	Restrict network path; SSO proxy where possible; enhanced logging; documented exception and migration plan.	High
Role design grants write access to users who only need read access	Excess privilege increases error and abuse potential.	Role matrix, entitlement export, job-function mapping	Split read/write roles; apply least privilege; test before deployment.	Medium

Role-Based Access Matrix

Role	Customer data	Financial reports	User administration	Security logs	Production changes
Support Analyst	Read limited	None	Password reset only	None	None
Finance Analyst	Read limited	Read/Export	None	None	None
System Administrator	Technical only	None	Manage technical accounts	Read operational	Approved changes
SOC Analyst	Minimum needed for investigation	None	Disable/escalate only	Read/Search	None
Security Administrator	As needed for security duties	None	Security/IAM administration	Read/Search/Admin	Security tooling only

Access Lifecycle Control

- **Joiner:** Access is role-based, manager-approved, and limited to required systems.
- **Mover:** Role change triggers review/removal of obsolete privileges before or with new access.
- **Leaver:** Access is disabled promptly based on separation timing; tokens, keys, and shared secrets are addressed.
- **Privileged:** Enhanced approval, MFA, logging, recertification, and time-limited access where supported.
- **Service accounts:** Named owner, defined purpose, least privilege, non-interactive login where appropriate, secret rotation, and monitoring.